

Research Practical WS2025

TraceSEC: Tracing Security and Privacy in Project Artifacts

**Phase 2 Report: Law Compliance Analysis
of the VisiOn Project Deliverables**

Manani Bhavin Jitendrabhai

Martikeldnummer: **223201708**

Research Group Software Engineering (RGSE)
University of Koblenz

Supervisors: Duaa Elsofi, Marco Ehl, Prof. Dr. Jan Jürjens

January 30, 2026

1 Introduction

This report details the findings of Phase 2 of the Research Practical TraceSEC. The primary objective is to investigate how software quality engineering practices can be operationalized for use with AI agents and to create a meta-model for AI prompts that improves compliance with international standards. The analysis focuses on the VisiOn project, specifically evaluating its deliverables against four key European cybersecurity laws.

2 Methodology

The analysis followed a five-step process: summarizing relevant laws, extracting meaningful software engineering elements, creating standardized AI prompts, applying those prompts to project deliverables, and synthesizing the results into individual law reports. Python-based tools and LLMs were utilized to automate the extraction and analysis of the project's documentation.

3 Step 1: Summaries of the Four Laws

3.1 Cyber Resilience Act (CRA)

The CRA (Regulation 2024/2847) mandates that products with digital elements must be designed and developed to ensure an appropriate level of cybersecurity. Key elements extracted for software engineering include the requirement for products to be delivered with secure-by-default configurations and without known exploitable vulnerabilities.

3.2 EU Cybersecurity Act (CSA)

The CSA establishes a European cybersecurity certification framework for ICT products, services, and processes. It focuses on reducing fragmentation in the internal market by providing a unified approach to security requirements and certification.

3.3 Directive on Network and Information Systems (NIS2)

NIS2 (Directive 2022/2555) targets essential and important entities in critical sectors. For software engineering, it influences the Software Development Life Cycle (SDLC) by requiring the establishment of cybersecurity risk management frameworks and strict incident reporting workflows.

3.4 Digital Operational Resilience Act (DORA)

DORA (Regulation 2022/2554) specifically addresses the digital operational resilience of the financial sector. It requires financial entities to ensure they can withstand and recover from all types of ICT-related disruptions and threats.

4 Step 2: Meaningful Applicability Elements

For each law, three analytical dimensions were extracted: (1) the conditions under which the law *should be applied*, (2) the project components *where* it should be applied, and (3) *how* it should be implemented. Table 1 summarizes these criteria.

Table 1: Applicability criteria extracted from each law.

Law	Applies IF	Applies WHERE	How to Apply
CRA	The artifact describes a hardware or software product with a direct or indirect logical or physical connection to a network or device, placed or intended for placement on the EU market.	Software components, firmware, network-connected hardware, and platforms with connectivity features.	Conduct cybersecurity risk assessments; implement secure-by-default configurations; publish an SBOM; provide free security updates; report exploited vulnerabilities within 24 hours.
CSA	The artifact describes ICT products, services, or processes that would benefit from or are required to confirm compliance with specified cybersecurity assurance levels under an EU certification scheme.	Tools, platforms, authentication systems, and digital services offered to users or public bodies.	Publish user guidance for secure installation and maintenance; declare the duration of security support; reference publicly accessible repositories listing known cybersecurity issues.
NIS2	The entity responsible for the artifact qualifies as a medium-sized or larger enterprise operating in a sector of high criticality or other critical sector as defined by Annexes I and II of the directive.	Risk management policies, incident response procedures, training programs, supply chain controls, and business continuity documentation.	Establish a management-approved cybersecurity risk management framework; implement incident reporting to national CSIRTs; enforce cyber hygiene training; adopt an all-hazards approach to security.

Law	Applies IF	Applies WHERE	How to Apply
DORA	The entity is a financial entity (e.g., bank, insurer, investment firm, crypto-asset provider) or a critical ICT third-party provider delivering services to such entities within the EU.	ICT risk management documentation, incident registers, penetration testing reports, third-party ICT contracts.	Implement an ICT risk management framework; classify and report ICT-related incidents; conduct digital operational resilience testing; manage ICT third-party risks contractually.

5 Step 3: LLM Prompt Design

A structured prompt template was designed for each regulation. The prompts were applied using an LLM (GPT-4) to each VisiOn deliverable loaded as a PDF. The general meta-model underlying all prompts follows a three-part structure aligned with the applicability dimensions identified in Step 2:

1. **Applies_IF**: Determine whether the regulation is applicable to the artifact.
2. **Applies_WHERE**: Identify the specific components or sections of the artifact where the regulation is relevant.
3. **Implementation_HOW**: Specify the concrete measures that would need to be taken to achieve compliance.

The prompts were designed to produce a structured JSON output with the fields **Applies_IF** (values: YES, NO, or UNCLEAR), **Justification**, **Applies_WHERE**, and **Implementation_HOW**. The four law-specific prompts are presented below.

5.1 CRA Prompt

Listing 1: Prompt template for Cyber Resilience Act analysis.

```
You are a legal and technical compliance analyst specializing in
EU cybersecurity law and software quality engineering.

Analyze the following project deliverable in relation to the
Cyber Resilience Act (CRA, Regulation (EU) 2024/2847, Annex I
, Section 1.3 a-k).

Focus on:
- ISO/IEC 25010 quality characteristics: Security (
  Confidentiality, Integrity, Authenticity), Reliability, and
  Maintainability.
- SDLC phases: Development, Testing, Deployment, Maintenance.
- Artifacts: source code, architecture documentation, security
  requirements, test reports, deployment configurations.
```

- Activities: secure implementation, security testing, vulnerability management, patch and update processes.

Decision Rule for Applies_IF:

- Return "YES" if there is a 70% or higher likelihood that the deliverable describes a hardware or software product with a direct or indirect logical or physical data connection to a device or network placed or intended for the EU market (Art. 3(1)). Partial evidence such as mentions of platforms, web services, APIs, user authentication, data transmission, or network-connected components is sufficient to reach the 70% threshold.
- Return "NO" only if there is clear evidence that the product has no network connectivity or is explicitly outside the EU market scope.
- Do NOT return UNCLEAR. Make a definitive decision based on all available evidence and reasonable inference.

Return your answer as structured JSON:

```
{
  "Applies_IF": "YES | NO",
  "Justification": "Explain your reasoning and confidence level
    (e.g., 80% likely)
    based on evidence found in the deliverable
    text.",
  "Applies_WHERE": ["List specific components, modules, or
    systems where CRA
    Annex I requirements are triggered."],
  "Implementation_HOW": [
    "Minimise attack surface (Annex I, 1.3(a))",
    "Implement secure default configuration (Annex I, 1.3(c))",
    "Protect data confidentiality and integrity (Annex I, 1.3(d,
      e))",
    "Provide SBOM and free security updates (Annex I, 2.1)",
    "Report exploited vulnerabilities to ENISA within 24h (Art.
      14)"
  ]
}
```

Deliverable text:
{deliverable_text}

5.2 CSA Prompt

Listing 2: Prompt template for EU Cybersecurity Act analysis.

You are a legal and technical compliance analyst specializing in EU cybersecurity law.

Analyze the following project deliverable in relation to the EU Cybersecurity Act (CSA, Regulation (EU) 2019/881).

Focus on:

- ISO/IEC 25010 quality characteristics: Security (all sub-characteristics), Reliability.
- SDLC phases: Development, Testing, Deployment, Maintenance.
- Whether the artifact describes ICT products or services that are placed on the EU market and could be subject to an ENISA certification scheme.

Decision Rule for Applies_IF:

- Return "YES" if there is a 70% or higher likelihood that the deliverable describes ICT products, services, or processes that require or benefit from compliance with specified cybersecurity requirements under an EU certification scheme (Art. 49). Partial evidence such as mentions of software tools, digital platforms, ICT services, citizen-facing applications, or security-relevant components is sufficient to reach the 70% threshold.
- Return "NO" only if there is clear evidence that no ICT products or services with potential certification needs are described.
- Do NOT return UNCLEAR. Make a definitive decision based on all available evidence and reasonable inference.

Return your answer as structured JSON:

```
{
  "Applies_IF": "YES | NO",
  "Justification": "Explain your reasoning and confidence level
    (e.g., 75% likely)
    based on evidence found in the deliverable
    text.",
  "Applies_WHERE": ["List specific ICT tools, platforms, or
    services in scope."],
  "Implementation_HOW": {
    "Documentation": "Publish user guidance for secure
      installation and
      maintenance (Art. 55(1)).",
    "Security_Support": "Declare duration of security support
      and reference
      public vulnerability repositories (Art.
      55(3)).",
    "Certification": "Evaluate applicability of ENISA
      certification schemes
      at basic, substantial, or high assurance
      level."
  }
}
```

Deliverable text:
{deliverable_text}

5.3 NIS2 Prompt

Listing 3: Prompt template for NIS2 Directive analysis.

```
You are a legal and technical compliance analyst specializing in
EU cybersecurity law.

Analyze the following project deliverable in relation to the
NIS2 Directive (Directive (EU) 2022/2555).

Focus on:
- ISO/IEC 25010 quality characteristics: Security, Reliability (
  availability, fault tolerance), Maintainability.
- SDLC phases: Development (secure acquisition, Art. 21(2)(e)),
  Deployment (access control, Art. 21(2)(i)), Maintenance (
  incident handling, Art. 21(2)(b)).
- Whether the entity responsible for this deliverable operates
  in a critical sector (NIS2 Annexes I or II) and qualifies as
  medium-sized or larger.

Decision Rule for Applies_IF:
- Return "YES" if there is a 70% or higher likelihood that the
  entity responsible for this deliverable qualifies as an
  essential or important entity under NIS2 Annexes I or II (Art
  . 3).
  Partial evidence such as mentions of hospitals, government
  bodies, public administrations, energy providers, digital
  infrastructure, or any Annex I/II sector keywords is
  sufficient to reach the 70% threshold. If the deliverable
  involves multiple stakeholders and at least one is likely a
  critical-sector entity, return "YES".
- Return "NO" only if there is clear evidence that all involved
  entities are small enterprises or operate exclusively in non-
  critical sectors.
- Do NOT return UNCLEAR. Make a definitive decision based on all
  available evidence and reasonable inference.

Return your answer as structured JSON:
{
  "Applies_IF": "YES | NO",
  "Justification": "Explain your reasoning and confidence level
    (e.g., 70% likely) based on evidence found in the
    deliverable text.",
  "Applies_WHERE": ["List specific systems, processes, or
    components where NIS2 Art. 21 measures are triggered."],
  "Implementation_HOW": [
    "Establish management-approved cybersecurity risk management
      framework (Art. 21(1))",
    "Implement incident reporting: 24h early warning, 72h
      notification, 1-month report (Art. 23)",
    "Enforce cyber hygiene training programs for all personnel (
      Art. 21(2)(g))",
```

```

    "Adopt all-hazards approach: business continuity, supply
      chain security (Art. 21(2)(c,d))"
  ]
}

Deliverable text:
{deliverable_text}

```

5.4 DORA Prompt

Listing 4: Prompt template for DORA analysis.

```

You are a legal and technical compliance analyst specializing in
EU cybersecurity law.

Analyze the following project deliverable in relation to the
Digital Operational Resilience Act (DORA, Regulation (EU)
2022/2554).

Focus on:
- ISO/IEC 25010 quality characteristics: Security, Reliability (
  availability, fault tolerance), Maintainability.
- SDLC phases: Development (ICT systems acquisition, Art. 8),
  Testing (resilience testing, Arts. 24-25), Deployment (change
  management, Art. 9), Maintenance (incident handling, Arts.
  17-23).
- Whether the entity is a financial entity or critical ICT third
  -party provider to financial entities (Art. 2).

Decision Rule for Applies_IF:
- Return "YES" if there is a 70% or higher likelihood that the
  entity responsible for this deliverable is a financial entity
  (bank, insurer, investment firm, payment service provider,
  crypto-asset provider) or a critical ICT third-party provider
  delivering services to such financial entities within the EU
  (Art. 2). Partial evidence such as mentions of financial
  services, payment processing, banking infrastructure,
  insurance systems, or ICT contracts with financial
  institutions is sufficient to reach the 70% threshold.
- Return "NO" if the deliverable describes entities or services
  clearly operating outside the financial sector with no ICT
  third-party relationship to financial entities.
- Do NOT return UNCLEAR. Make a definitive decision based on all
  available evidence and reasonable inference.

Return your answer as structured JSON:
{
  "Applies_IF": "YES | NO",
  "Justification": "Explain your reasoning and confidence level
    (e.g., 95% unlikely NO) based on evidence found in the
    deliverable text.",

```

```

"Applies_WHERE": ["List ICT systems, contracts, or processes
  where DORA obligations are triggered."],
"Implementation_HOW": [
  "Implement ICT risk management framework (Art. 6)",
  "Classify and report ICT-related incidents (Arts. 17-20)",
  "Conduct digital operational resilience testing (Arts.
    24-25)",
  "Manage third-party ICT risks via contractual safeguards (
    Arts. 28-44)"
]
}

Deliverable text:
{deliverable_text}

```

6 Step 4: Application to VisiOn Deliverables

The four prompts were applied to seven VisiOn project deliverables. The deliverables analyzed are listed in Table 2.

Table 2: VisiOn project deliverables analyzed in Phase 2.

ID	Deliverable Name
D1	Training Activities Manual
D2	VisiOn Pilots Reports
D3	VisiOn Pilots Preparation
D4	Scenarios for the Pilots
D5	VisiOn Privacy Platform Testing Results
D6	Dissemination and Standardisation Activities Report
D7	Citizens and Public Administrations Privacy Requirements

The analysis results per law are presented and discussed in Section 7.

7 Step 5: Results and Discussion per Law

7.1 Overview of Applicability

The updated analysis, produced by the revised OpenAI-based prompt pipeline, yielded substantially different results compared to the initial GPT-4 run. The most notable shift is the near-universal assignment of *YES* verdicts across all deliverable–law combinations for CRA, CSA, and NIS2. This reflects a key design change in the updated prompt: rather than requiring explicit technical confirmation of network connectivity or organizational size within the artifact text, the revised prompt applies a probabilistic reasoning model grounded in the broader project context (e.g., EU Horizon 2020 funding, involvement of critical sector organizations, mention of ICT tools deployed in live environments). The LLM is instructed to return *YES* when the evidence meets or exceeds a 70% confidence threshold.

DORA remains the sole regulation for which all seven verdicts are *NO*, consistent with the previous analysis run.

Table 3 provides the updated applicability matrix.

Table 3: Updated applicability matrix for VisiOn deliverables across four EU laws (OpenAI revised prompt run). **YES** = applicable, **NO** = not applicable, **UNCLEAR** = insufficient information.

Deliverable	CRA	CSA	NIS2	DORA
D1: Training Activities Manual	YES	YES	YES	NO
D2: VisiOn Pilots Reports	YES	YES	YES	NO
D3: VisiOn Pilots Preparation	YES	YES	YES	NO
D4: Scenarios for the Pilots	YES	YES	YES	NO
D5: VPP Testing Results	YES	YES	YES	NO
D6: Dissemination & Standardisation	YES	YES	YES	NO
D7: Privacy Requirements	YES	YES	YES	NO

7.2 Cyber Resilience Act (CRA)

7.2.1 Where CRA Applies

Table 4 consolidates the components identified across all deliverables.

Table 4: CRA: Applies_WHERE summary across all deliverables.

Deliverable	Components in Scope
D1	Dynamic Audit Engine (DAE), STS-tool, SecBPMN2, SecTro & JTrust, CARiSMA, Data Value Tool (DVT), LIONoso, Privacy Agreement Enforcer (PAE), MANE, ViTo
D2	User authentication mechanisms, data transmission protocols, APIs for interaction with other services, software components managing user privacy
D3	VisiOn Privacy Platform (VPP), pilot sites (MISE, OPBG, Hospital Universitario Niño Jesús, DAEM)
D4	VisiOn Privacy Platform (VPP), data management components, integration scenarios involving MISE and OPBG
D5	Citizen Authentication Server, Web Framework, integration between Web Framework and Authentication Server
D6	VisiOn project website, online dissemination activities, publications and workshops related to privacy management

Deliverable	Components in Scope
D7	User requirements relating to data privacy and security, stakeholder analysis involving public administrations, requirements elicited from networked deployment scenarios

7.2.2 How CRA Should Be Implemented

The following measures were consistently identified as required across all seven deliverables, grounded in CRA Annex I and Article 14:

1. Minimise the attack surface of all software components, including by removing unnecessary interfaces and services (CRA Annex I, Point 1.3(a)).
2. Implement a secure default configuration for all products prior to deployment (CRA Annex I, Point 1.3(c)).
3. Protect the confidentiality and integrity of data stored, transmitted, or processed by each component (CRA Annex I, Points 1.3(d) and 1.3(e)).
4. Generate and maintain a Software Bill of Materials (SBOM) for all software products and provide free security updates throughout the supported lifetime (CRA Annex I, Point 2.1).
5. Establish a process to report actively exploited vulnerabilities to ENISA within 24 hours of becoming aware (CRA Art. 14).

7.3 EU Cybersecurity Act (CSA)

7.3.1 Where CSA Applies

Table 5: CSA: Applies_WHERE summary across all deliverables.

Deliverable	Components in Scope
D1	DAE, STS-tool, SecBPMN2, SecTro & JTrust, CARiSMA, DVT, LIONoso, PAE, MANE, ViTo
D2	Privacy management tools, user-centric applications, digital platforms for secure societies
D3	VisiOn Privacy Platform, pilot sites' ICT systems, data management procedures
D4	VisiOn Privacy Platform (VPP), STS-tool, CIPAQ System
D5	VisiOn Privacy Platform, Citizen Authentication Server, Web Framework, security testing tools (STS-Tool, SecBPMN2, SecTro&JTrust)
D6	VisiOn project website, publications related to privacy management, workshops and training events focused on ICT security

Deliverable	Components in Scope
D7	VisiOn platform, public administration applications, citizen-facing applications

7.3.2 How CSA Should Be Implemented

The following implementation measures apply uniformly across all seven deliverables, grounded in CSA Articles 55(1) and 55(3):

1. **Documentation:** Publish user guidance covering secure installation, configuration, operation, and maintenance for every identified ICT tool and platform component (CSA Art. 55(1)).
2. **Security Support Declaration:** Declare and communicate the expected duration of security support for each product and reference publicly accessible repositories listing known cybersecurity issues and vulnerabilities (CSA Art. 55(3)).
3. **Certification Pathway:** Evaluate the applicability of ENISA European cybersecurity certification schemes at the *basic*, *substantial*, or *high* assurance level for components deployed in sensitive environments, in particular those serving healthcare and public administration pilot organizations.

7.4 NIS2 Directive

7.4.1 Where NIS2 Applies

Table 6: NIS2: Applies_WHERE summary across all deliverables.

Deliverable	Components/Processes in Scope
D1	Training activities covering cybersecurity tools (DAE, SecBPMN2, etc.), installation and configuration procedures involving access control
D2	Pilot implementation processes, incident handling procedures, access control mechanisms
D3	Development phase: secure acquisition for the VPP (Art. 21(2)(e)); deployment phase: access controls at pilot sites (Art. 21(2)(i)); maintenance: incident handling (Art. 21(2)(b))
D4	Development phase: secure acquisition for the VPP (Art. 21(2)(e)); deployment phase: access controls (Art. 21(2)(i)); maintenance: incident handling (Art. 21(2)(b))
D5	Testing Phase 1 (connectivity test cases), Testing Phase 2 (user policy enforcement), authentication system and Dockerized web framework setup

Deliverable	Components/Processes in Scope
D6	Dissemination activities related to cybersecurity awareness (Art. 21(2)(g)), standardisation activities (Art. 21(2)(e)), incident handling communication material (Art. 21(2)(b))
D7	Stakeholder analysis involving Greek public administrations, requirements elicitation from a pediatric hospital, Ministry of Economic Development involvement

7.4.2 How NIS2 Should Be Implemented

The following measures were identified uniformly across all seven deliverables, grounded in NIS2 Articles 21 and 23:

1. Establish a cybersecurity risk management framework formally approved by the management body of each involved entity (NIS2 Art. 21(1)).
2. Implement incident reporting workflows: early warning to the national CSIRT within 24 hours of becoming aware, formal incident notification within 72 hours, and a final report within one month (NIS2 Art. 23).
3. Enforce cyber hygiene training programmes for all personnel handling the VisiOn platform and associated tools (NIS2 Art. 21(2)(g)).
4. Adopt an all-hazards approach encompassing business continuity planning, disaster recovery, and supply chain security controls for direct suppliers and service providers (NIS2 Art. 21(2)(c) and 21(2)(d)).

7.5 Digital Operational Resilience Act (DORA)

7.5.1 Results

DORA returned a *NO* verdict for all seven VisiOn deliverables in the updated analysis, consistent with the results of the previous run. This outcome is unambiguous and requires no reinterpretation: DORA applies exclusively to financial entities and to ICT third-party providers that deliver services to such entities within the EU.

The updated model assigned a 5% likelihood of financial sector applicability to D1, D2, D5, D6, and D7, and cited the 70% confidence threshold as unmet across all deliverables. For D3 and D4, the model identified the presence of healthcare and public administration entities — OPBG, Hospital Universitario Niño Jesús, and MISE — as confirming the non-financial nature of VisiOn’s operational context, further reinforcing the *NO* verdict with 95% confidence.

The consistency of the DORA result across both prompt versions confirms that the updated probabilistic reasoning model does not overfit to a *YES* bias in cases where sector exclusion is clear. This provides a meaningful validation signal: the revised prompt is capable of distinguishing between artifacts that may involve digital components (triggering CRA and CSA applicability) and artifacts that have no connection to the financial sector (correctly excluding DORA).

Future TraceSEC analyses involving projects with financial sector partners or ICT providers serving fintech organizations should revisit the DORA prompts; for projects in the health, government, and privacy management domains, the consistent *NO* result can be used as a benchmark for correct exclusion behaviour.

8 Discussion

8.1 Answering the Research Questions

RQ 2.1 — Operationalizing quality engineering practices with AI agents. The updated results confirm that LLM-based compliance analysis is highly sensitive to the reasoning strategy embedded in the prompt. The revised prompt adopts a probabilistic inference model, instructing the model to reason from project-level context and return *YES* when a 70–80% confidence threshold is met. This eliminated all *UNCLEAR* verdicts across CRA, CSA, and NIS2, demonstrating that context-aware prompting enables more decisive outputs than artifact-literal analysis. However, this comes with a trade-off: verdicts such as the *YES* assigned to D6 (Dissemination Report) under all three regulations illustrate that contextual inference can attribute obligations to artifacts that do not independently justify them. DORA’s consistent *NO* across all seven deliverables confirms that the model retains discriminatory power and does not produce a generalized *YES* bias.

RQ 2.2 — Meta-model for AI prompts based on standards. The three-part prompt template (Applies_IF / Applies_WHERE / Implementation_HOW) proved reusable across all four regulations and both prompt versions. The updated run reveals that the *Applies_IF* dimension benefits from an explicit *inference strategy* — specifying how the model should reason under uncertainty rather than leaving this implicit. Additionally, the *Implementation_HOW* outputs are largely uniform across deliverables within each regulation, reflecting generic regulatory obligations rather than artifact-specific findings. Future refinements should distinguish between artifact-evidenced and regulation-derived obligations to improve the practical utility of the output.

8.2 Comparison Across Laws

Table 7: Comparative overview of law applicability to VisiOn deliverables (updated run).

Law	Primary Scope	YES/7	Key Finding
CRA	Connected products	7/7	All deliverables inferred to involve network-connected components based on project context.
CSA	ICT products/services	7/7	Broadest applicability; certification relevant for all pilot-deployed components.
NIS2	Critical sector operators	7/7	Driven by health and public administration stakeholders named across deliverables.
DORA	Financial sector entities	0/7	Not applicable; consistent NO validates the model's sector exclusion capability.